

令和5年度 情報セキュリティマネジメント試験

科目 A・B 公開問題 (問1～問15) 中日英対照学習版

問題来源：IPA 令和5年度公開問題 | 本PDF为学习辅助：词汇对照 + 中文题意/选项翻译

問1～12：原文 → 中文题意 → 单词表 → 选项对照

問13～15：先单词表 → 再贴原题完整页面 (含表格) → 再给完整中文意思

問1 / 问题 1

■ 原文 (日文)

情報セキュリティ管理基準 (平成28年) に関する記述のうち、適切なものはどれか。

■ 中文题意

关于《信息安全管理基准》(平成28年)的叙述中，恰当的是哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
情報セキュリティ管理基準	Information Security Management Standards	信息安全管理基准
記述	description / statement	叙述、记述
適切	appropriate / correct	恰当、正确
ガバナンス基準	governance standards	治理基准
管理策基準	control standards	管理措施基准
マネジメント基準	management standards	管理基准
構成	composition / consist of	构成
整合性	consistency / alignment	一致性、整合性
とっている	maintain / take	采取、保持
対策	countermeasure	对策
選択する	select	选择
トップマネジメント	top management	最高管理层
自組織	one's own organization	本组织
合致する	conform / match	符合、一致
実施する	implement / carry out	实施

■ 选项对照

ア. “ガバナンス基準”，“管理策基準”及び“マネジメント基準”の三つの基準で構成されている。

→ 由“治理基准”“管理措施基准”以及“管理基准”这三项基准构成。

イ. JIS Q 27001:2014 (情報セキュリティマネジメントシステム - 要求事項) 及び JIS Q 27002:2014 (情報セキュリティ管理策の実践のための規範) との整合性をとっている。

→ 与 JIS Q 27001:2014 (信息安全管理体系—要求事项) 及 JIS Q 27002:2014 (信息安全管理措施实施规范) 保持一致。

ウ. 情報セキュリティ対策は，“管理策基準”に挙げられた管理策の中から選択することとしている。

→ 规定信息安全对策应从“管理措施基准”所列管理措施中选择。

エ. トップマネジメントは，“マネジメント基準”に挙げられている事項の中から，自組織に合致する事項を選択して実施することとしている。

→ 规定最高管理层应从“管理基准”所列事项中选择符合本组织的事项并实施。

問2 / 问题 2

■ 原文 (日文)

入室時と退室時にIDカードを用いて認証を行い，入退室を管理する。このとき，入室時の認証に用いられなかったIDカードでの退室を許可しない，又は退室時の認証に用いられなかったIDカードでの再入室を許可しないコントロールを行う仕組みはどれか。

■ 中文题意

进出房间时使用 ID 卡进行认证来管理出入室。此时，不允许用进室时未用于认证的 ID 卡退室，或不允许用退室时未用于认证的 ID 卡再次进室——实现这种控制的机制是哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
入室時	when entering a room	进室时
退室時	when leaving a room	退室时
認証	authentication	认证
入退室	entry and exit	出入室
管理する	manage / control	管理
用いられなかった	was not used	未被使用
許可しない	do not permit	不允许
再入室	re-entry	再次进入
コントロール	control	控制
仕組み	mechanism / system	机制、结构
アンチパスバック	anti-passback	防回传 (防尾随出入控制)
インターロックゲート	interlock gate	互锁门 (联动闸门)
パニックオープン	panic open	紧急开门 (恐慌开启)

■ 选项对照

ア. TPMOR (Two Person Minimum Occupancy Rule)

→ TPMOR (两人最低在室规则)

イ. アンチパスバック

→ 防回传 (anti-passback)

ウ. インターロックゲート

→ 互锁门 / 联动闸门

エ. パニックオープン

→ 紧急开门 (恐慌开启)

問3 / 问题 3

■ 原文 (日文)

デジタルフォレンジックスの説明はどれか。

■ 中文题意

下列哪一项是对数字取证 (digital forensics) 的说明？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
デジタルフォレンジックス	digital forensics	数字取证 / 电子取证
説明	explanation	说明
サイバー攻撃	cyber attack	网络攻击
脅威情報	threat intelligence	威胁情报
標準化された方法	standardized method	标准化方法
記述し	describe	记述、描述
セキュリティ対策機器	security devices	安全防护设备
提供する	provide	提供
受信メール	received email	收到的邮件
添付された	attached	附带的
実行ファイル	executable file	可执行文件
動作させた	executed / run	使其运行
不正な振る舞い	malicious behavior	不正当行为
保存前に	before saving	保存之前
確認する	confirm / check	确认、检查
インシデント	incident	事件 (安全事故)
発生時	at the time of occurrence	发生时
法的な証拠	legal evidence	法律证据
収集し	collect	收集
保管し	preserve / store	保管
調査分析	investigation and analysis	调查分析
盗聴	eavesdropping	窃听
暗号化	encryption	加密

■ 选项对照

ア. サイバー攻撃に関連する脅威情報を標準化された方法で記述し、その脅威情報をセキュリティ対策機器に提供すること

→ 用标准化方法记述与网络攻击相关的威胁情报，并将其提供给安全防护设备。

イ. 受信メールに添付された実行ファイルを動作させたときに、不正な振る舞いがないかどうかをメールボックスへの保存前に確認すること

→ 在将收到邮件中的附件可执行文件运行时，于保存到邮箱前确认其是否有不正当行为。

ウ. 情報セキュリティインシデント発生時に、法的な証拠となるデータを収集し、保管し、調査分析すること

→ 在信息安全事件发生时，收集、保管并调查分析可作为法律证据的数据。

エ. 内部ネットワークにおいて、通信データを盗聴されないように暗号化すること

→ 在内部网络中对通信数据进行加密，以免被窃听。

問4 / 问题 4

■ 原文（日文）

暗号方式に関する記述のうち，適切なものはどれか。

■ 中文题意

关于加密方式的叙述中，恰当的是哪一项？

■ 重点单词（日文 → English → 中文）

日文	English	中文
暗号方式	cryptographic method	加密方式 / 密码体制
公開鍵暗号方式	public-key cryptography	公钥加密方式
共通鍵暗号方式	symmetric-key cryptography	对称密钥（共通密钥）加密方式
合成数	composite number	合数
素因数分解	prime factorization	素因数分解
困難	difficult	困难
安全性の根拠	basis of security	安全性的依据
セッション	session	会话
異なる鍵	different key	不同的密钥
繰り返し利用	reuse repeatedly	反复使用
仕様	specification	规格、规范
標準化	standardization	标准化
ベンダー	vendor	厂商
独自の仕様	proprietary specification	专有规格
実装	implementation	实现、部署
大量のデータ	large amount of data	大量数据
短い時間	short time	短时间
適している	suitable	适合

■ 选项对照

ア. 公開鍵暗号方式，共通鍵暗号方式ともに，大きな合成数の素因数分解が困難であることが安全性の根拠である。

→ 公钥加密与对称密钥加密都以“大合数的素因数分解困难”作为安全性依据。

イ. 公開鍵暗号方式では原則としてセッションごとに異なる鍵を利用するが，共通鍵暗号方式では一度生成した鍵を複数のセッションに繰り返し利用する。

→ 公钥加密原则上每个会话使用不同密钥，而对称密钥加密则把一次生成的密钥在多个会话中反复使用。

ウ. 公開鍵暗号方式は仕様が標準化されているが，共通鍵暗号方式はベンダーによる独自の仕様で実装されることが一般的である。

→ 公钥加密规格已标准化，而对称密钥加密通常由厂商按专有规格实现。

エ. 大量のデータを短い時間で暗号化する場合には，公開鍵暗号方式よりも共通鍵暗号方式が適している。

→ 在短时间内加密大量数据时，对称密钥加密比公钥加密更合适。

問5 / 问题 5

■ 原文 (日文)

セキュアハッシュ関数SHA-256を用いてファイルA及びファイルBのハッシュ値を算出すると、どちらも全く同じ次に示すハッシュ値n (16進数で示すと64桁) となった。この結果から考えられることとして、適切なものはどれか。

■ 中文题意

使用安全哈希函数 SHA-256 分别计算文件 A 与文件 B 的哈希值，两者得到完全相同的哈希值 n (以十六进制表示为 64 位)。据此可得出的恰当结论是哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
セキュアハッシュ関数	secure hash function	安全哈希函数
ハッシュ値	hash value	哈希值
算出する	calculate	计算、算出
全く同じ	exactly the same	完全相同
16進数	hexadecimal	十六进制
桁	digit(s)	位数
考えられること	what can be inferred	可推断的事情
内容を変更せずに	without changing the content	不改变内容地
再度	again	再次
異なる	different	不同
データ量	data volume / size	数据量
バイト	byte	字节
連結させた	concatenated	连接起来的
桁数	number of digits	位数
同じである	are the same	相同

■ 选项对照

ア. ファイルAとファイルBの各内容を変更せずに再度ハッシュ値を算出すると、ファイルAとファイルBのハッシュ値が異なる。

→ 若不改变文件 A、B 的内容再次计算哈希值，则二者哈希值会不同。

イ. ファイルAとファイルBのハッシュ値nのデータ量は64バイトである。

→ 文件 A 与文件 B 的哈希值 n 的数据量是 64 字节。

ウ. ファイルAとファイルBを連結させたファイルCのハッシュ値の桁数は16進数で示すと128桁である。

→ 把文件 A 与 B 连接成文件 C 后，其哈希值的十六进制位数是 128 位。

エ. ファイルAの内容とファイルBの内容は同じである。

→ 文件 A 的内容与文件 B 的内容相同。

問6 / 问题 6

■ 原文 (日文)

迷惑メール対策のSPF (Sender Policy Framework) の仕組みはどれか。

■ 中文题意

作为垃圾邮件对策的 SPF (Sender Policy Framework) 机制是哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
迷惑メール	spam / junk mail	垃圾邮件
対策	countermeasure	对策
仕組み	mechanism	机制
送信側ドメイン	sender-side domain	发送方域名
管理者	administrator	管理员
正規の	legitimate / authorized	正规的、合法的
メールサーバ	mail server	邮件服务器
登録し	register	注册
受信側	receiving side	接收方
参照して	refer to / look up	参照、查阅
判定を行う	make a judgment	进行判定
デジタル署名	digital signature	数字签名
施し	apply	施加
検証する	verify	验证
第三者	third party	第三方
スパムメール	spam mail	垃圾邮件
送信元	sender / source	发送源
データベース	database	数据库
ファイアウォール	firewall	防火墙
通過した	passed through	通过了
要求パケット	request packet	请求包
応答パケット	response packet	响应包
動的に	dynamically	动态地
制御する	control	控制

■ 选项对照

ア. 送信側ドメインの管理者が，正規の送信側メールサーバのIPアドレスをDNSに登録し，受信側メールサーバでそれを参照して，IPアドレスの判定を行う。

→ 发送方域名管理员将正规发送邮件服务器的 IP 地址登记到 DNS，接收方邮件服务器据此参照并对 IP 地址进行判定。

イ. 送信側メールサーバでメッセージにデジタル署名を施し，受信側メールサーバでそのデジタル署名を検証する。

→ 发送方邮件服务器对邮件施加数字签名，接收方邮件服务器验证该数字签名。

ウ. 第三者によって提供されている，スパムメールの送信元IPアドレスのデータベースを参照して，スパムメールの判定を行う。

→ 参照第三方提供的垃圾邮件发送源 IP 地址数据库，进行垃圾邮件判定。

工. ファイアウォールを通過した要求パケットに対する応答パケットかどうかを判断して、動的に迷惑メールの通信を制御する。

→ 判断是否为针对已通过防火墙的请求包的响应包，从而动态控制垃圾邮件通信。

問7 / 问题 7

■ 原文 (日文)

Webアプリケーションにおけるセキュリティ上の脅威とその対策に関する記述のうち、適切なものはどれか。

■ 中文题意

关于 Web 应用中安全威胁及其对策的叙述，恰当的是哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
Webアプリケーション	Web application	Web 应用程序
脅威	threat	威胁
対策	countermeasure	对策
OSコマンドインジェクション	OS command injection	OS 命令注入
防ぐ	prevent	防止
発行する	issue / generate	签发、生成
セッションID	session ID	会话 ID
推測困難な乱数	hard-to-guess random number	难以推测的随机数
SQLインジェクション	SQL injection	SQL 注入
問合せ	query	查询
プレースホルダ	placeholder / prepared statement	占位符 (预编译参数)
クロスサイトスクリプティング	cross-site scripting (XSS)	跨站脚本攻击
直接参照できない	cannot be directly referenced	无法直接引用
セッションハイジャック	session hijacking	会话劫持
シェル	shell	命令行外壳
起動できない	cannot be launched	无法启动

■ 选项对照

- ア. OSコマンドインジェクションを防ぐために、Webアプリケーションが発行するセッションIDに推測困難な乱数を使用する。
- 为防止 OS 命令注入，对 Web 应用签发的会话 ID 使用难以推测的随机数。
- イ. SQLインジェクションを防ぐために、Webアプリケーション内でデータベースへの問合せを作成する際にプレースホルダを使用する。
- 为防止 SQL 注入，在 Web 应用内构造数据库查询时使用占位符 (预编译)。
- ウ. クロスサイトスクリプティングを防ぐために、Webサーバ内のファイルを外部から直接参照できないようにする。
- 为防止跨站脚本，使 Web 服务器内的文件无法从外部直接引用。
- エ. セッションハイジャックを防ぐために、Webアプリケーションからシェルを起動できないようにする。
- 为防止会话劫持，使 Web 应用无法启动 shell。

問8 / 问题 8

■ 原文 (日文)

電子署名法に関する記述のうち，適切なものはどれか。

■ 中文题意

关于《电子签名法》的叙述中，恰当的是哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
電子署名法	Act on Electronic Signatures	电子签名法
電子署名	electronic signature	电子签名
電磁的記録	electromagnetic record	电磁记录
処理できない	cannot process	无法处理
含まれる	include / be included	包含
民事訴訟法	Code of Civil Procedure	民事诉讼法
押印	seal / stamp impression	盖章
同様の効力	same legal effect	同样的效力
認められる	be recognized / accepted	被承认
認証業務	certification services	认证业务
認証局	certificate authority (CA)	认证机构 / 证书颁发机构
限られる	be limited to	仅限于
共通鍵暗号技術	symmetric cryptography	对称密钥密码技术

■ 选项对照

ア. 電子署名には，電磁的記録ではなく，かつ，コンピュータで処理できないものも含まれる。

→ 电子签名也包括非电磁记录、且计算机无法处理的内容。

イ. 電子署名には，民事訴訟法における押印と同様の効力が認められる。

→ 电子签名被承认具有与民事诉讼法中盖章同样的效力。

ウ. 電子署名の認証業務を行うことができるのは，政府が運営する認証局に限られる。

→ 能够从事电子签名认证业务的仅限于政府运营的认证机构。

エ. 電子署名は共通鍵暗号技術によるものに限られる。

→ 电子签名仅限于基于对称密钥密码技术的方式。

問9 / 問題 9

■ 原文 (日文)

情報システムのインシデント管理に対する監査で判明した状況のうち、監査人が、指摘事項として監査報告書に記載すべきものはどれか。

■ 中文题意

在对信息系统事件管理的审计中所查明的状况里，审计人员应作为指出事项写入审计报告的是哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
インシデント管理	incident management	事件管理
監査	audit	审计
判明した	was found / revealed	查明的、弄清の
状況	situation	状况
監査人	auditor	审计人员
指摘事項	finding / pointed-out issue	指出事项、发现问题
監査報告書	audit report	审计报告
記載すべき	should be recorded	应记载
対応手順	response procedure	应对流程
周知	make known / notify	周知、传达
被害を受けた	suffered damage	遭受损害
影響を最小に	minimize the impact	将影响最小化
規程	rules / regulations	规程、规定
バックアップ	backup	备份
発生箇所	location of occurrence	发生地点
影響度合い	degree of impact	影响程度
連絡・報告ルート	contact/reporting route	联络与报告路径
共通になっている	is the same / common	是共通的
記録を残し	keep records	留下记录
責任者	person in charge	负责人
承認を得る	obtain approval	获得批准
定められている	is stipulated	被规定

■ 选项对照

ア. インシデント対応手順が作成され、関係者への周知が図られている。

→ 已制定事件应对流程，并已向相关人员周知。

イ. インシデントによってデータベースが被害を受けた場合の影響を最小にするために、規程に従ってデータのバックアップをとっている。

→ 为将事件导致数据库受损时的影响最小化，按规程进行数据备份。

ウ. インシデントの種類や発生箇所、影響度合いに関係なく、連絡・報告ルートが共通になっている。

→ 无论事件种类、发生地点、影响程度如何，联络与报告路径都是统一的。

エ. 全てのインシデントについて、インシデント記録を残し、責任者の承認を得ることが定められている。

→ 规定对所有事件都要留下事件记录，并取得负责人批准。

問10 / 问题 10

■ 原文 (日文)

HTTPのcookieに関する記述のうち，適切なものはどれか。

■ 中文题意

关于 HTTP cookie 的叙述中，恰当的是哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
cookie	cookie	Cookie (浏览器小型数据)
含まれる情報	contained information	所含信息
HTTPヘッダ	HTTP header	HTTP 头
一部として	as part of	作为一部分
送信される	is sent / transmitted	被发送
保存される	is stored	被保存
Webブラウザ	Web browser	网页浏览器
全て暗号化	encrypt all	全部加密
クライアント	client	客户端
有効期限	expiration date	有效期限
設定する	set / configure	设定

■ 选项对照

ア. cookieに含まれる情報はHTTPヘッダの一部として送信される。

→ cookie 中包含的信息作为 HTTP 头的一部分被发送。

イ. cookieに含まれる情報はWebサーバだけに保存される。

→ cookie 中包含的信息仅保存在 Web 服务器上。

ウ. cookieに含まれる情報はWebブラウザが全て暗号化して送信する。

→ cookie 中包含的信息由 Web 浏览器全部加密后发送。

エ. クライアントがcookieに含まれる情報の有効期限を設定する。

→ 由客户端设定 cookie 所含信息的有效期限。

問11 / 問題 11

■ 原文 (日文)

BPMの説明はどれか。

■ 中文题意

下列哪一项是对 BPM 的说明？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
BPM	Business Process Management	业务流程管理
企業活動	corporate activities	企业活动
生産	production	生产
物流	logistics	物流
販売	sales	销售
財務	finance	财务
人事	HR / personnel	人事
一元管理	centralized management	一元化管理
経営資源	management resources	经营资源
全体最適	overall optimization	整体最优
業務プロセス	business process	业务流程
分析，設計，実行，改善	analyze, design, execute, improve	分析、设计、执行、改善
マネジメントサイクル	management cycle	管理循环
取り入れ	incorporate	引入
見直し	review / revision	重新审视
統合	integration	整合
継続的に	continuously	持续地
顧客データベース	customer database	客户数据库
保守サービス	maintenance service	维护服务
問合せ	inquiry	问询
クレーム	complaint	投诉
一貫して	consistently / end-to-end	一贯地、端到端地
部品の供給	parts supply	零部件供应
リアルタイム	real time	实时
交換	exchange	交换
在庫の削減	inventory reduction	削减库存
リードタイム	lead time	交货周期
短縮	shortening	缩短

■ 选项对照

ア. 企業活動の主となる生産，物流，販売，財務，人事などの業務の情報を一元管理することによって，経営資源の全体最適を実現する。

→ 通过对企业核心活动（生产、物流、销售、财务、人事等）业务信息进行一元化管理，实现经营资源整体最优。（≈ERP）

イ. 業務プロセスに分析，設計，実行，改善のマネジメントサイクルを取り入れ，業務プロセスの改善見直しや最適なプロセスへの統合を継続的に実施する。

→ 把分析、设计、执行、改善的管理循环引入业务流程，持续进行流程改善与向最优流程整合。（≈BPM）

ウ. 顧客データベースを基に，商品の販売から保守サービス，問合せやクレームへの対応など顧客に関する業務プロセスを一貫して管理する。

→ 基于客户数据库，对从商品销售到维护服务、问询与投诉应对等客户相关业务流程进行一贯管理。（≈CRM）

エ. 部品の供給から製品の販売までの一連の業務プロセスの情報をリアルタイムで交換することによって，在庫の削減とリードタイムの短縮を実現する。

→ 通过实时交换从零部件供应到产品销售的一系列流程信息，实现削减库存与缩短交货周期。（≈SCM）

問12 / 问题 12

■ 原文（日文）

品質管理において，結果と原因との関連を整理して，魚の骨のような図にまとめたものはどれか。

■ 中文题意

在质量管理中，把结果与原因的关系整理后，汇总成类似鱼骨形状的图，是哪一项？

■ 重点单词（日文 → English → 中文）

日文	English	中文
品質管理	quality control / management	质量管理
結果と原因	result and cause	结果与原因
関連	relationship	关联
整理して	organize / arrange	整理
魚の骨	fishbone	鱼骨
図にまとめた	summarized in a diagram	汇总成图
管理図	control chart	控制图
特性要因図	cause-and-effect / fishbone diagram	特性要因图（鱼骨图）
パレート図	Pareto chart	帕累托图
ヒストグラム	histogram	直方图

■ 选项对照

ア. 管理図

→ 控制图

イ. 特性要因図

→ 特性要因图（鱼骨图）

ウ. パレート図

→ 帕累托图

エ. ヒストグラム

→ 直方图

問13 / 问题 13 (案例题)

■ 1. 重点单词 (日文 → English → 中文)

日文	English	中文
分析・計測機器	analysis / measuring instruments	分析/测量仪器
販売	sales	销售
試料	sample / specimen	试样、样品
分析受託業務	contracted analysis services	委托分析业务
分析機器メーカー	analytical instrument manufacturer	分析仪器厂商
情報セキュリティリスクアセスメント	information security risk assessment	信息安全风险评估
手順	procedure	步骤、程序
年一度	once a year	一年一次
情報資産	information asset	信息资产
機密性	confidentiality	机密性
完全性	integrity	完整性
可用性	availability	可用性
評価値	evaluation value / score	评价值
3段階	three levels	三个等级
最大値	maximum value	最大值
重要度	importance level	重要度
脅威	threat	威胁
脆弱性	vulnerability	脆弱性
リスク値	risk value	风险值
算出する	calculate	计算
当該	the relevant / said	该、相应的
情報資産管理台帳	information asset register	信息资产管理台账
記載する	record / write down	记载
しきい値	threshold	阈值
受容可能なリスク	acceptable risk	可接受风险
保有以外のリスク対応	risk treatment other than retention	持有以外的风险应对
情報セキュリティリーダー	information security leader	信息安全负责人
年次の	annual	年度的
抜粋	excerpt	摘录
従業員	employee	员工
健康診断	health checkup	健康体检
行動規範	code of conduct	行为规范
社内ルール	internal rules	公司内部规则
掲載している	posted / published	刊登、登载
会社情報	company information	公司信息
分析結果	analysis results	分析结果
精度を向上させる	improve accuracy	提高精度

日文	English	中文
開発した技術	developed technology	开发的技术
設問	question / sub-question	设问（小题）
該当するもの	applicable items	符合条件的项
組合せ	combination	组合
解答群	answer choices	解答群

■ 2. 原题全文（保留原卷排版/表格）

以下为 IPA 原题页面截图，表格与图示格式与原卷一致。

問13 A社は、分析・計測機器などの販売及び機器を利用した試料の分析受託業務を行う分析機器メーカーである。A社では、図1の“情報セキュリティリスクアセスメント手順”に従い、年一度、情報セキュリティリスクアセスメントを行っている。

- ・ 情報資産の機密性，完全性，可用性の評価値は，それぞれ0～2の3段階とする。
- ・ 情報資産の機密性，完全性，可用性の評価値の最大値を，その情報資産の重要度とする。
- ・ 脅威及び脆弱性の評価値は，それぞれ0～2の3段階とする。
- ・ 情報資産ごとに，様々な脅威に対するリスク値を算出し，その最大値を当該情報資産のリスク値として情報資産管理台帳に記載する。ここで，情報資産の脅威ごとのリスク値は，次の式によって算出する。
$$\text{リスク値} = \text{情報資産の重要度} \times \text{脅威の評価値} \times \text{脆弱性の評価値}$$
- ・ 情報資産のリスク値のしきい値を5とする。
- ・ 情報資産ごとのリスク値がしきい値以下であれば受容可能なリスクとする。
- ・ 情報資産ごとのリスク値がしきい値を超えた場合は，保有以外のリスク対応を行う

図1 情報セキュリティリスクアセスメント手順

A社の情報セキュリティリーダーであるBさんは，年次の情報セキュリティリスクアセスメントを行い，結果を情報資産管理台帳に表1のとおり記載した。

表 1 A 社の情報資産管理台帳（抜粋）

情報資産	機密性の評価値	完全性の評価値	可用性の評価値	情報資産の重要度	脅威の評価値	脆弱性の評価値	リスク値
(一) 従業員の健康診断の情報	2	2	2	(省略)	2	2	(省略)
(二) 行動規範などの社内ルール	1	2	1	(省略)	1	1	(省略)
(三) 自社 Web サイトに掲載している会社情報	0	2	2	(省略)	2	2	(省略)
(四) 分析結果の精度を向上させるために開発した技術	2	2	1	(省略)	2	1	(省略)

設問 表 1 中の各情報資産のうち、保有以外のリスク対応を行うべきものはどれか。該当するものだけを全て挙げた組合せを、解答群の中から選べ。

解答群

- | | |
|-----------------|-----------------|
| ア (一), (二) | イ (一), (二), (三) |
| ウ (一), (二), (四) | エ (一), (三) |
| オ (一), (三), (四) | カ (一), (四) |
| キ (二), (三) | ク (二), (三), (四) |
| ケ (二), (四) | コ (三), (四) |

■ 3. 原题对应中文意思

问13 A 社は销售分析/测量仪器等、并承接使用这些仪器的试样分析委托业务的分析仪器厂商。A 社按照图1的“信息安全风险评估步骤”，每年进行一次信息安全风险评估。

图1 信息安全风险评估步骤

- 信息资产的机密性、完整性、可用性评价值，分别按 0~2 共 3 个等级。
- 将信息资产机密性、完整性、可用性评价值的最大值，作为该信息资产的重要度。
- 威胁及脆弱性的评价值，分别按 0~2 共 3 个等级。
- 针对每项信息资产，计算面对各种威胁的风险值，并将其最大值作为该信息资产的风险值，记载到信息资产管理台账。

其中，信息资产针对每种威胁的风险值按下列公式计算：

风险值 = 信息资产的重要度 × 威胁的评价值 × 脆弱性的评价值

- 信息资产风险值的阈值定为 5。
- 若各项信息资产的风险值在阈值以下，则视为可接受风险。
- 若各项信息资产的风险值超过阈值，则采取“持有以外”的风险应对。

A 社的信息安全负责人 B，进行了年度信息安全风险评估，并将结果如表1记载到信息资产管理台账。

表1 A 社的信息资产管理台账（摘录）

- (一) 员工健康体检信息：机密性2、完整性2、可用性2；威胁评价值2、脆弱性评价值2（重要度与风险值栏见原表）
(二) 行为规范等公司内部规则：机密性1、完整性2、可用性1；威胁1、脆弱性1
(三) 刊登在本公司网站上的公司信息：机密性0、完整性2、可用性2；威胁2、脆弱性2
(四) 为提高分析结果精度而开发的技术：机密性2、完整性2、可用性1；威胁2、脆弱性1

设问 表1中的各项信息资产里，应采取“持有以外”风险应对的是哪些？请从解答群中选出仅包含全部相应项的组合。

解答群

- ア (一)，(二) イ (一)，(二)，(三)
ウ (一)，(二)，(四) エ (一)，(三)
オ (一)，(三)，(四) カ (一)，(四)
キ (二)，(三) ク (二)，(三)，(四)
ケ (二)，(四) コ (三)，(四)
-

問14 / 问题 14 (案例题)

■ 1. 重点单词 (日文 → English → 中文)

日文	English	中文
旅行商品	travel products	旅游商品
販売しており	selling	在销售
顧客情報	customer information	客户信息
取り扱っている	handle / deal with	处理、经手
保有する	possess / hold	持有
ファイルサーバ	file server	文件服务器
保存されている	is stored	被保存
フォルダ	folder	文件夹
磁気テープ	magnetic tape	磁带
毎週土曜日	every Saturday	每周六
バックアップ	backup	备份
設定されている	is configured	已设定
2世代分	two generations	两代 (两份世代备份)
隣にある	next to	旁边的
キャビネット	cabinet	柜子
保管されている	is kept / stored	被保管
年に一度	once a year	一年一次
リスクの見直し	risk review	风险重新审视
実施している	is carrying out	正在实施
データ保管	data storage / custody	数据保管
まとめた	summarized	汇总了
省略	omitted	省略
バックアップ対象	backup target	备份对象
設定ミス	configuration mistake	设置错误
復旧できなくなる	become unrestorable	变得无法恢复
低減する	reduce / mitigate	降低
対策を検討し	consider measures	研究对策
効果が期待できる	expected to be effective	可期待有效果
取得する	obtain / take (a backup)	取得 (备份)
代わりに	instead of	取而代之
7世代分	seven generations	七代
リスト	list	列表
比較し	compare	比较
合致しているか	whether they match	是否一致
確認する	confirm / check	确认
必ず2名で	always by two people	必须由两人
媒体	media	介质

日文	English	中文
外付けハードディスク	external hard disk	外接硬盘
変更する	change	变更
二組み	two sets	两套
うち一組み	one of the sets	其中一套
遠隔地	remote location	远程地点
組合せ	combination	组合
解答群	answer choices	解答群

■ 2. 原题全文 (保留原卷排版/表格)

以下为 IPA 原题页面截图，表格与图示格式与原卷一致。

問14 A社は旅行商品を販売しており、業務の中で顧客情報を取り扱っている。A社が保有する顧客情報は、A社のファイルサーバ1台に保存されている。ファイルサーバは、顧客情報を含むフォルダにある全てのデータを磁気テープに毎週土曜日にバックアップするよう設定されている。バックアップは2世代分が保存され、ファイルサーバの隣にあるキャビネットに保管されている。

A社では年に一度、情報セキュリティに関するリスクの見直しを実施している。情報セキュリティリーダーであるE主任は、A社のデータ保管に関するリスクを見直して図1にまとめた。

- | |
|---|
| <ol style="list-style-type: none">1. (省略)2. (省略)3. (省略)4. バックアップ対象とするフォルダの設定ミスによって、データが復旧できなくなる。 |
|---|

図1 A社のデータ保管に関するリスク(抜粋)

E主任は、図1の4のリスクを低減するための対策を検討し、効果が期待できるものを選んだ。

設問 次の対策のうち、効果が期待できるものを二つ挙げた組合せを、解答群の中から選べ。

- (一) 週1回バックアップを取得する代わりに、毎日1回バックアップを取得して7世代分保存する。
- (二) バックアップ後に、磁気テープ中のファイルのリストと、ファイルサーバのバックアップ対象ファイルのリストとを比較し、合致しているかを確認する。
- (三) バックアップ対象とするフォルダの設定を、必ず2名で行うようにする。
- (四) バックアップ用の媒体を磁気テープから外付けハードディスクに変更する。
- (五) バックアップを二組み取得し、うち一組みを遠隔地に保管する。

解答群

ア (一), (二)

イ (一), (三)

ウ (一), (四)

エ (一), (五)

オ (二), (三)

カ (二), (四)

キ (二), (五)

ク (三), (四)

ケ (三), (五)

コ (四), (五)

■ 3. 原题对应中文意思

问14 A 社销售旅游商品，业务中处理客户信息。A 社持有的客户信息保存在 A 社的 1 台文件服务器上。文件服务器设定为：每周六将包含客户信息的文件夹中全部数据备份到磁带。备份保存 2 代，并保管在文件服务器旁边的柜子里。

A 社每年实施一次与信息安全相关的风险重新审视。信息安全负责人 E 主任重新审视了 A 社数据保管相关风险，并汇总为图1。

图1 A 社数据保管相关风险（摘录）

- 1.（省略） 2.（省略） 3.（省略）
4. 因备份对象文件夹的设置错误，导致数据无法恢复。

E 主任研究了用于降低图1中第4项风险的对策，并选出了可期待有效果的对策。

设问 下列对策中，选出可期待有效果的两项组合，从解答群中选择。

对策

- (一) 不以每周备份1次，改为每天备份1次，并保存7代。
- (二) 备份后，比较磁带中的文件列表与文件服务器备份对象文件列表是否一致。
- (三) 备份对象文件夹的设置必须由两人进行。
- (四) 将备份用介质由磁带改为外接硬盘。
- (五) 取得两套备份，其中一套保管在远程地点。

解答群

- ア (一)，(二) イ (一)，(三) ウ (一)，(四)
エ (一)，(五) オ (二)，(三) カ (二)，(四)
キ (二)，(五) ク (三)，(四) ケ (三)，(五)
コ (四)，(五)
-

問15 / 问题 15 (案例题)

■ 1. 重点单词 (日文 → English → 中文)

日文	English	中文
消費者向け	for consumers	面向消费者
化粧品販売	cosmetics sales	化妆品销售
電子メール	email	电子邮件
送受信	send and receive	收发
クラウドサービスプロバイダ	cloud service provider	云服务提供商
メールサービス	mail service	邮件服务
アカウント	account	账户
情報システム部	information systems department	信息系统部
管理している	manage	管理
認証	authentication	认证
利用者ID	user ID	用户 ID
パスワード	password	密码
あらかじめ登録しておいた	registered in advance	事先登记好的
スマートフォン	smartphone	智能手机
認証アプリ	authenticator app	认证应用
2要素認証	two-factor authentication	双要素认证
承認のリクエスト	approval request	批准请求
1分以内に承認	approve within 1 minute	1分钟内批准
ログインできる	can log in	可以登录
社外のネットワーク	external network	外部网络
社内システム	internal system	公司内部系统
貸与されたPC	company-issued PC	公司配发的电脑
VPN接続	VPN connection	VPN 连接
マルウェア対策ソフト	anti-malware software	反恶意软件
導入されており	has been installed	已导入、已安装
マルウェア定義ファイル	malware definition file	恶意软件定义文件
更新する	update	更新
チェックし	check	检查
セキュリティ担当者	security officer	安全负责人
知らせる	notify	通知
販売促進部	sales promotion department	销售促进部
在宅で勤務	work from home	居家办公
部下	subordinate	下属
報告を受けた	received a report	收到报告
委託している	outsourced / commissioned	委托
直接会った	met in person	直接见过面
頻繁にやり取り	frequently exchange messages	频繁往来

日文	English	中文
返信する形	in the form of a reply	以回复形式
挨拶文	greeting text	寒暄用语
急ぎの対応	urgent response	紧急应对
添付されていたファイル	attached file	所附文件
見慣れないエラー	unfamiliar error	不熟悉的错误
閲覧できた	could view	能够查看
不審に思った	found it suspicious	感到可疑
電話で確認した	confirmed by phone	电话确认
不具合	malfunction / anomaly	故障、异常
不審な事象	suspicious event	可疑现象
切断している	is disconnected	已切断
向かうことは可能	can go (to the office)	可以前往
掛かる	take (time)	需要 (时间)
持参し	bring along	带来
オフラインで	offline	离线地
最新版	latest version	最新版
フルスキャン	full scan	全盘扫描
指示をした	gave instructions	作出指示
検出された	was detected	被检测到
ベンダー	vendor	厂商
公開した	published / released	公开、发布
検出可能	detectable	可检测
判明した	became clear / was found	判明、弄清
インシデント	incident	事件
問題点を整理し	organize the issues	整理问题点
再発を防止する	prevent recurrence	防止再次发生
対策を講じる	take countermeasures	采取对策
最も適切な	most appropriate	最恰当的
起動したらすぐに	as soon as it starts	一启动就立刻
自動的に	automatically	自动地
構成する	configure	配置
差出人	sender	发件人
受信した場合	when received	收到时
削除する	delete	删除
社内ルールに定める	stipulate in internal rules	在公司规则中规定
設定を変更する	change the settings	更改设定
一旦PCに保存し	temporarily save to the PC	暂时保存到电脑
スキャンを実行してから	after running a scan	执行扫描之后

■ 2. 原题全文 (保留原卷排版/表格)

以下为 IPA 原题页面截图，表格与图示格式与原卷一致。

問15 消費者向けの化粧品販売を行う A 社では、電子メール（以下、メールという）の送受信にクラウドサービスプロバイダ B 社が提供するメールサービス（以下、B サービスという）を利用している。A 社が利用する B サービスのアカウントは、A 社の情報システム部が管理している。

〔B サービスでの認証〕

B サービスでの認証は、利用者 ID とパスワードに加え、あらかじめ登録しておいたスマートフォンの認証アプリを利用した 2 要素認証である。入力された利用者 ID とパスワードが正しかったときは、スマートフォンに承認のリクエストが来る。リクエストを 1 分以内に承認した場合は、B サービスにログインできる。

〔社外のネットワークからの利用〕

社外のネットワークから社内システム又はファイルサーバを利用する場合、従業員は貸与された PC から社内ネットワークに VPN 接続する。

〔PC でのマルウェア対策〕

従業員に貸与された PC には、マルウェア対策ソフトが導入されており、マルウェア定義ファイルを毎日 16 時に更新するように設定されている。マルウェア対策ソフトは、毎日 17 時に、各 PC のマルウェア定義ファイルが更新されたかどうかをチェックし、更新されていない場合は情報システム部のセキュリティ担当者に更新されていないことをメールで知らせる。

〔メールに関する報告〕

ある日の 15 時頃、販売促進部の情報セキュリティリーダーである C 課長は、在宅で勤務していた部下の D さんから、メールに関する報告を受けた。報告を図 1 に示す。

- ・販売促進キャンペーンを委託している E 社の F さんから 9 時 30 分にメールが届いた。
- ・F さんとは直接会ったことがある。この数か月頻繁にやり取りもしていた。
- ・そのメールは、これまでのメールに返信する形で作成されており、メールの本文には販売キャンペーンの内容や F さんがよく利用する挨拶文が記載されていた。
- ・急ぎの対応を求める旨が記載されていたので、メールに添付されていたファイルを開いた。
- ・メールの添付ファイルを開いた際、特に見慣れないエラーなどは発生せず、ファイルの内容も閲覧できた。
- ・ファイルの内容を確認した後、返信した。
- ・11 時頃、D さんのスマートフォンに、承認のリクエストが来たが、B サービスにログインしようとしたタイミングではなかったので、リクエストを承認しなかった。
- ・12 時までと急いでいた割にその後の返信がなく不審に思ったので、14 時 50 分に F さんに電話で確認したところ、今日はメールを送っていないと言われた。
- ・現在までのところ、PC の処理速度が遅くなったり、見慣れないウィンドウが表示されたりするなどの不具合や不審な事象は発生していない。
- ・現在、PC は、インターネットには接続しているが、社内ネットワークへの VPN 接続は切断している。
- ・D さんはすぐに会社に向かうことは可能で、D さんの自宅から会社までは 1 時間掛かる。

図 1 D さんからの報告

C 課長は、すぐに PC を会社を持参し、オフラインでマルウェア対策ソフトの定義ファイルを最新版に更新した後、フルスキャンを実施するよう、D さんに指示をした。スキャンを実行した結果、D さんの PC からマルウェアが検出された。このマルウェアは、マルウェア対策ソフトのベンダーが 9 時に公開した最新の定義ファイルで検出可能であることが判明した。

A 社では、今回のマルウェア感染による情報セキュリティインシデントの問題点を整理し、再発を防止するための対策を講じることにした。

設問 A 社が講じることにした対策はどれか。解答群のうち、最も適切なものを選べ。

解答群

- ア PC が起動したらすぐに自動的に VPN 接続するように、PC を構成する。
- イ これまでメールをやり取りしたことがない差出人からメールを受信した場合は、添付されているファイルを開かず、すぐに削除するよう社内ルールに定める。
- ウ マルウェア定義ファイルは、10 分ごとに更新されるように、マルウェア対策ソフトの設定を変更する。
- エ マルウェア定義ファイルは、8 時にも更新されるように、マルウェア対策ソフトの設定を変更する。
- オ メールに添付されたファイルを開く場合は、一旦 PC に保存し、マルウェア対策ソフトでスキャンを実行してから開くよう社内ルールに定める。

■ 3. 原题对应中文意思

问15 面向消费者销售化妆品的 A 社，使用云服务提供商 B 社提供的邮件服务（以下简称 B 服务）收发电子邮件（以下简称邮件）。A 社使用的 B 服务账户由 A 社信息系统部管理。

【B 服务中的认证】

B 服务的认证是：除用户 ID 与密码外，再加上事先登记的智能手机认证应用，进行双要素认证。当输入的用户 ID 与密码正确时，手机会收到批准请求。若在 1 分钟内批准该请求，即可登录 B 服务。

【从外部网络使用】

从外部网络使用公司内部系统或文件服务器时，员工用公司配发的 PC 连接公司内部网络的 VPN。

【PC 上的恶意软件对策】

配发给员工的 PC 已安装反恶意软件，设定为每天 16 时更新恶意软件定义文件。反恶意软件每天 17 时检查各 PC 的定义文件是否已更新；若未更新，则邮件通知信息系统部的安全负责人。

【关于邮件的报告】

某日约 15 时，销售促进部的信息安全负责人 C 课长，收到居家办公下属 D 关于邮件的报告。报告如图1所示。

图1 D 的报告

- 9:30 收到受委托开展促销活动的 E 社 F 发来的邮件。
- 曾与 F 直接见过面；近几个月也频繁往来。
- 该邮件是以回复以往邮件的形式写的，正文有促销内容及 F 常用寒暄语。
- 因写着要求紧急处理，于是打开了附件。
- 打开附件时没有不熟悉的错误，内容也能查看。
- 确认文件内容后作了回复。
- 约 11 时，D 的手机收到批准请求，但并非自己要登录 B 服务的时机，因此没有批准。
- 对方说赶在 12 点前，之后却没有回复，感到可疑，于是 14:50 电话联系 F，对方说今天没发邮件。
- 截至目前，PC 没有变慢、未出现陌生窗口等异常或可疑现象。
- 当前 PC 连着互联网，但已切断通往公司内部网络的 VPN。
- D 可以马上回公司；从家到公司约需 1 小时。

C 课长立刻指示 D：把 PC 带到公司，离线将反恶意软件定义文件更新到最新版后，执行全盘扫描。扫描结果显示，D 的 PC 检出恶意软件。已判明：该恶意软件可用厂商于当天 9 时发布的最新定义文件检出。

A 社决定整理本次恶意软件感染所导致信息安全事件的问题点，并采取防止再次发生的对策。

设问 A 社决定采取的对策是哪一项？从解答群中选出最恰当的一项。

解答群

- ア 将 PC 配置为启动后立即自动进行 VPN 连接。
- イ 规定：若收到从未往来过的发件人邮件，不要打开附件，立即删除。
- ウ 将反恶意软件设定改为：定义文件每 10 分钟更新一次。
- エ 将反恶意软件设定改为：定义文件在 8 点也进行更新。
- オ 规定：打开邮件附件时，先保存到 PC，用反恶意软件扫描后再打开。